SECURITY / 2026

INFORME DE AUDITORÍA WEB

Paloma Casabona | Portfolio profesional

www.palomacasabona.com

EVALUACIÓN PASIVA · OWASP ZAP 2.17.0

Comparativa local / producción

Hallazgos, interpretación, salvaguardas y plan de acción

0 ALERTAS ALTAS

4 medias · 2 bajas · 5 informativas (producción)

01 / Resumen ejecutivo

Diagnóstico basado en dos informes de OWASP ZAP Baseline aportados por la propietaria, generados el 2 de noviembre de 2026. No se ha realizado explotación manual ni verificación independiente de los hallazgos.

DICTAMEN

No se identificaron alertas de severidad alta en el análisis pasivo de producción. Las alertas restantes son indicios de configuración o endurecimiento, no pruebas de intrusión ni de vulnerabilidades explotables. El formulario de contacto y la política CORS merecen revisión prioritaria.

Métrica	Copia local	Sitio publicado
Objetivo	http://host.docker.internal:3000	https://www.palomacasabona.com
Tipos de alertas medias	6	4
Tipos de alertas bajas	6	2
Tipos informativos	2	5
Alertas altas	0	0
Endpoints observados	40	41
Infraestructura	Python SimpleHTTP 3.9.13	Cloudflare + aplicación desplegada

Lectura correcta de las cifras

Las cantidades anteriores representan categorías de alertas, no número de vulnerabilidades únicas. Una misma alerta puede aparecer en varias URL; además, el resumen de consola de la ejecución local (11 advertencias) y el HTML local (12 categorías de riesgo medio/bajo) no coinciden exactamente. Para esta comparación se ha utilizado el detalle de ambos informes HTML.

Qué mejoró al pasar a producción

En el despliegue público desaparecen alertas locales relativas a anti-clickjacking, X-Content-Type-Options, Permissions-Policy y divulgación de la versión de Python. La cabecera CSP de producción incorpora frame-ancestors. Esto sugiere que el servidor local no reproduce las protecciones de Cloudflare.

LÍMITE CRÍTICO DE LA PRUEBA

El servidor local de Python solo sirve archivos estáticos y devuelve 501 Not Implemented para /api/contact; por tanto, no evalúa el comportamiento real del backend. La auditoría pasiva tampoco verifica de forma concluyente XSS, inyección, controles de abuso, autenticación ni lógica de negocio.

02 / Alcance y metodología

Se ejecutó OWASP ZAP 2.17.0, modalidad Baseline, contra una copia estática local y posteriormente contra el dominio público. El escaneo realizó rastreo y análisis pasivo de respuestas; no equivale a una prueba de penetración completa.

Dimensión	Qué se evaluó / qué no
Cobertura	Respuestas HTTP, cabeceras, enlaces y recursos descubiertos durante el rastreo.
Sitio local	HTML, CSS, JS, imágenes y rutas; backend dinámico no ejecutado por SimpleHTTP.
Producción	41 endpoints detectados; 97 % de métodos GET y 2 % POST según el reporte.
Exclusiones	Sin pruebas activas de explotación, sin revisión exhaustiva de código, sin autenticación, sin carga de tráfico ni prueba de entrega de correo.
Evidencia	Resultados proporcionados por la usuaria; sin acceso a logs, configuración Cloudflare ni código completo.

Cómo interpretar la severidad

Alta: potencial impacto elevado, pero ninguna alerta alta observada. Media: debilidad que merece análisis; no implica automáticamente exposición explotable. Baja: defensa en profundidad o configuración secundaria. Informativa: dato contextual o mejora operativa. Falso positivo: requiere confirmación manual; ZAP informa cero falsos positivos marcados, lo que no significa que todas las alertas sean reales.

Indicadores de respuesta

En producción, ZAP indica 90 % de respuestas 2xx, 4 % 3xx, 4 % 4xx y 81 % de respuestas clasificadas como lentas. Son estadísticas de esta ejecución, no métricas de rendimiento representativas: faltan umbrales, distribución de tiempos, ubicación y repetición. No se puede concluir que el sitio sea lento para los usuarios a partir de este dato aislado.

Hallazgos que persisten en producción

Riesgo	Hallazgo	Juicio inicial
Medio	Formulario sin token anti-CSRF	Verificar controles reales del endpoint
Medio	CSP permite estilos inline	Endurecimiento recomendado
Medio	CORS con origen *	Evaluar por tipo de recurso y API
Medio	Recursos externos sin SRI	Mitigación según proveedor / fuentes
Bajo	COEP ausente	Aplicar solo si compatible
Bajo	HSTS ausente en dos respuestas API	Comprobar cabeceras por ruta

03 / Hallazgos: análisis y salvaguardas

Cada ficha distingue la observación verificable en el informe de la interpretación del riesgo. Las medidas propuestas deben probarse antes de desplegarse.

F01 Formulario de contacto: ausencia de anti-CSRF

CLASIFICACIÓN

MEDIO / POR CONFIRMAR

Qué observó ZAP

ZAP encuentra el formulario POST /api/contact sin un campo oculto de token anti-CSRF; aparecen dos instancias en la página principal.

Qué significa el parámetro

CSRF significa falsificación de peticiones entre sitios: un tercero intenta provocar acciones en nombre de un visitante. Es especialmente relevante cuando la acción depende de una sesión autenticada o credenciales que el navegador envía automáticamente.

Interpretación y limitaciones

La mera ausencia de un token en un formulario público y anónimo no demuestra una vulnerabilidad CSRF. El riesgo práctico puede ser más bien spam, abuso del envío de mensajes o consumo de recursos. ZAP no demuestra que se pueda eludir ninguna defensa del endpoint.

Salvaguardas / medidas preventivas

Revisar el código de /api/contact: comprobar si usa cookies/sesión; validar Origin y/o Referer cuando proceda; añadir token CSRF si existe contexto autenticado; limitar tasa por IP/identidad, validar campos en servidor, usar honeypot como defensa complementaria y registrar intentos anómalos. No confiar únicamente en el honeypot.

Cómo verificar la corrección

Inspección del worker/backend, cabeceras y flujo de formulario; pruebas controladas en staging, sin generar mensajes reales.

F02 CSP: style-src permite unsafe-inline

CLASIFICACIÓN

MEDIO / CONFIRMADO COMO CONFIGURACIÓN

Qué observó ZAP

La política incluye style-src 'self' 'unsafe-inline' https://fonts.googleapis.com en páginas públicas.

Qué significa el parámetro

CSP (Content Security Policy) indica qué recursos puede cargar y ejecutar el navegador. style-src controla hojas de estilo; unsafe-inline permite estilos embebidos, reduciendo la restricción frente a inyecciones de CSS.

Interpretación y limitaciones

Es una configuración permisiva, pero no constituye una XSS confirmada. La política de scripts utiliza hashes y script-src-attr none, controles positivos que no deben perderse.

Salvaguardas / medidas preventivas

Inventariar estilos inline; moverlos a CSS externo o adoptar hashes/nonces donde sea viable; probar primero con Content-Security-Policy-Report-Only y revisar errores de consola antes de aplicar bloqueos. Mantener frame-ancestors none y restricciones de scripts.

Cómo verificar la corrección

Confirmar que la web conserva su diseño y funcionalidades sin unsafe-inline; comparar cabeceras finales y metaetiquetas CSP.

F03 CORS: Access-Control-Allow-Origin: *

CLASIFICACIÓN

MEDIO / CONTEXTUAL

Qué observó ZAP

ZAP observa Access-Control-Allow-Origin: * en HTML y recursos públicos como CSS, robots.txt y sitemap.xml.

Qué significa el parámetro

CORS regula si JavaScript de otro origen puede leer respuestas del navegador. El comodín * permite leer recursos públicos sin credenciales desde cualquier origen.

Interpretación y limitaciones

En páginas y archivos deliberadamente públicos esto puede ser aceptable; no demuestra fuga de datos privados. El riesgo aumenta si la misma regla se aplica a respuestas de API con información no destinada a terceros o a controles basados solo en IP.

Salvaguardas / medidas preventivas

Separar políticas por ruta: eliminar CORS donde no haga falta; permitir únicamente orígenes concretos en endpoints que lo requieran; evitar devolver datos sensibles en APIs públicas; no combinar orígenes arbitrarios con credenciales. Verificar también respuestas de error y preflight.

Cómo verificar la corrección

Revisar reglas de Cloudflare/Workers para /api/contact y otros endpoints, no solo recursos estáticos.

F04 SRI ausente en hojas de estilo externas

CLASIFICACIÓN

MEDIO / MEJORA DE CADENA DE SUMINISTRO

Qué observó ZAP

ZAP detecta etiquetas link que cargan hojas de estilo de Google Fonts sin atributo integrity.

Qué significa el parámetro

SRI (Subresource Integrity) permite fijar un hash esperado de un recurso externo; el navegador rechaza contenidos distintos. Es útil para recursos con contenido estable.

Interpretación y limitaciones

Las CSS de Google Fonts pueden variar por navegador y condiciones; añadir un hash fijo sin verificarlo puede romper las fuentes. No es correcto tratar automáticamente la ausencia de SRI como explotación.

Salvaguardas / medidas preventivas

Priorizar autoalojar las fuentes necesarias y servir CSS propio; reducir la lista de familias cargadas. Para bibliotecas externas versionadas y estáticas, usar SRI con crossorigin cuando corresponda. Mantener CSP restrictiva.

Cómo verificar la corrección

Revisar dependencias externas reales, cambios de CSS por agente de usuario y disponibilidad visual tras la migración.

F05 COEP ausente en páginas

CLASIFICACIÓN

BAJO / OPCIONAL SEGÚN ARQUITECTURA

Qué observó ZAP

Falta Cross-Origin-Embedder-Policy en tres respuestas HTML del sitio público.

Qué significa el parámetro

COEP controla la incorporación de recursos de otros orígenes y puede ser necesaria para aislamiento entre orígenes junto con COOP.

Interpretación y limitaciones

No todas las webs necesitan COEP estricto. Activar require-corp indiscriminadamente podría bloquear fuentes, imágenes o scripts externos.

Salvaguardas / medidas preventivas

Evaluar si se necesita aislamiento entre orígenes; probar compatibilidad de Google Fonts y recursos externos; aplicar require-corp o credentialless solo con justificación técnica y pruebas previas.

Cómo verificar la corrección

Inspección de la consola del navegador y pruebas de regresión en staging.

F06 HSTS no presente en dos respuestas API

CLASIFICACIÓN

BAJO / VERIFICAR POR RUTA

Qué observó ZAP

ZAP no encuentra Strict-Transport-Security en /api/ y en la respuesta de /api/contact; la página principal sí anuncia HSTS.

Qué significa el parámetro

HSTS indica al navegador que utilice HTTPS durante un periodo. Una política consistente en el host reduce riesgos de degradación a HTTP.

Interpretación y limitaciones

No significa que el sitio principal esté sirviendo tráfico inseguro. Conviene verificar si la diferencia se debe a un Worker, a rutas de error o a otra capa de Cloudflare.

Salvaguardas / medidas preventivas

Uniformar la cabecera HSTS en respuestas HTTPS de HTML y API, incluidas las de error, según la política del dominio; verificar redirección HTTP→HTTPS y el alcance de includeSubDomains antes de cambios.

Cómo verificar la corrección

Solicitudes HEAD/GET no destructivas a rutas representativas; inspección de configuración Cloudflare/Workers.

---

04 / Alertas informativas y falsos positivos

Las cinco categorías informativas del reporte de producción no implican, por sí mismas, un incidente de seguridad.

Categoría	Interpretación	Acción
Comentarios sospechosos	El texto “not a receipt from the email inbox” fue detectado por la palabra “from”. No se observa secreto ni dato sensible en la evidencia.	Mantener si aporta contexto; eliminar comentarios solo si revelan lógica sensible.
Contenido no almacenable	Algunas respuestas incluyen no-store; puede ser correcto en APIs y errores.	No cambiar sin revisar la sensibilidad.
Reexaminar Cache-Control	HTML con max-age=0, must-revalidate y robots.txt con max-age=14400.	Verificar política por tipo de recurso.
Contenido cacheable	CSS, imágenes y robots.txt cacheables: normal si son públicos.	Usar versionado para evitar contenido obsoleto.
Almacenable pero no reutilizable sin validar	Respuestas con max-age=0 que requieren revalidación.	No constituye fuga de datos por sí mismo.

Diferencias local / producción

El entorno local con python3 -m http.server no reproduce cabeceras, rutas, Workers, redirecciones ni controles de Cloudflare. Por ello, las alertas locales de Missing Anti-clickjacking Header, X-Content-Type-Options Header Missing, Server Leaks Version Information y algunas ausencias de CSP/Permissions-Policy no deben trasladarse sin más a producción. La versión pública sí presenta X-Frame-Options: DENY, X-Content-Type-Options: nosniff, CSP con frame-ancestors none y cabeceras de permisos, según la comprobación aportada.

NO EQUIVALE A UN FALSO POSITIVO MARCADO

El informe registra “False Positives: 0” porque no se etiquetaron alertas como falsas en ZAP. Nuestro análisis distingue hallazgos contextuales y efectos del entorno local; no modifica la clasificación original del escáner.

05 / Plan de remediación priorizado

Plazo sugerido	Acción	Responsable / evidencia de cierre
P1 · 1-3 días	Revisar /api/contact: validación, Origin, rate limiting, antispam y ausencia de dependencias de sesión.	Desarrollo backend / pruebas de endpoint y logs sin datos sensibles.
P1 · 1-3 días	Auditar reglas CORS de Cloudflare/Workers, especialmente API y errores.	Infraestructura / matriz de rutas y cabeceras.
P2 · 1-2 semanas	Reducir Google Fonts a las realmente usadas; estudiar autoalojamiento.	Frontend / inventario de fuentes y regresión visual.
P2 · 1-2 semanas	Eliminar progresivamente unsafe-inline de estilos tras probar Report-Only.	Frontend / política CSP y consola sin errores.
P2 · 1-2 semanas	Revisar HSTS en API y respuestas de error.	Cloudflare/Workers / evidencia de cabeceras consistentes.
P3 · cuando proceda	Decidir si COEP aporta valor; no activarlo sin pruebas.	Arquitectura / compatibilidad de recursos externos.
Continuo	Repetir Baseline tras cambios y guardar comparativas; monitorizar rendimiento real.	Seguridad / informe fechado y métricas Web Vitals.

Controles preventivos transversales

Antes del despliegue: revisión de código, secretos fuera del repositorio, pruebas de regresión, dependencias actualizadas y control de cambios. Durante la operación: HTTPS, registros mínimos sin información personal innecesaria, alertas de abuso del formulario y reglas de limitación de tráfico. Después de un hallazgo: registrar evidencia, corregir en rama de pruebas, volver a ejecutar ZAP y documentar la aceptación de riesgos residuales.

Indicadores de seguimiento (KPIs)

Indicador	Objetivo práctico
Alertas altas confirmadas	0; escalado inmediato si aparece alguna.
Alertas medias confirmadas	Plan y responsable para cada una; documentar descartes.
Cabeceras coherentes	Misma política aplicable en HTML, API y respuestas de error.
Abuso de formulario	Límites y alertas de volumen sin bloquear contactos legítimos.
Rendimiento	Medir LCP, INP y CLS con datos de usuarios y pruebas repetibles.

06 / Glosario técnico explicado

Término	Explicación sencilla
Endpoint / URL	Dirección o ruta que responde a una solicitud: /, /sobre-mi, /api/contact.
HTTP 2xx / 3xx / 4xx / 5xx	Éxito / redirección / error de solicitud / error del servidor.
GET / POST	GET solicita información; POST suele enviar datos o desencadenar una operación.
Cabecera HTTP	Metadato que acompaña una respuesta: tipo de contenido, caché, seguridad.
CSP	Reglas del navegador sobre qué recursos pueden cargarse o ejecutarse.
style-src / unsafe-inline	Regla de estilos de CSP / permiso para CSS embebido.
CORS / ACAO: *	Control de lectura entre orígenes / permiso general para recursos públicos.
CSRF / token	Ataque que induce una acción no deseada / valor que ayuda a validar su legitimidad.
SRI / integrity	Hash para comprobar que un recurso externo no ha cambiado.
HSTS	Instrucción para que el navegador use HTTPS en futuras conexiones.
COEP / COOP / CORP	Políticas de aislamiento e incorporación de recursos entre orígenes.
X-Frame-Options / frame-ancestors	Defensas que impiden incrustar una página en marcos ajenos (clickjacking).
X-Content-Type-Options: nosniff	Evita que el navegador interprete un tipo de archivo distinto al declarado.
Permissions-Policy	Restringe funciones del navegador, como cámara o geolocalización.
Cache-Control	Reglas sobre almacenamiento y reutilización de respuestas.
Sitemap / robots.txt	Mapa de URLs y recomendaciones para rastreadores; ambos son públicos.
False positive / riesgo residual	Alerta no aplicable tras revisión / riesgo que queda tras controles.

07 / Evidencia, referencias y límites

Fuentes primarias del presente informe

1. ZAP Scanning Report (local): http://host.docker.internal:3000; 2 nov 2026; OWASP ZAP 2.17.0; 40 endpoints; 6 categorías medias, 6 bajas, 2 informativas.

2. ZAP Scanning Report (producción): https://www.palomacasabona.com; 2 nov 2026, 17:50:59; OWASP ZAP 2.17.0; 41 endpoints; 4 categorías medias, 2 bajas, 5 informativas.

3. Cabeceras HTTP de producción aportadas en conversación: HTTP/2 200; Cloudflare; HSTS, CSP, X-Frame-Options, X-Content-Type-Options y Permissions-Policy en la página principal.

Fuentes técnicas contrastables

OWASP ZAP · Baseline Scan
https://www.zaproxy.org/docs/docker/baseline-scan/

OWASP · CSRF Prevention Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

OWASP · Content Security Policy Cheat Sheet
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

MDN · CORS
https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CORS

MDN · Subresource Integrity
https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

MDN · HTTP Strict Transport Security
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security

MDN · Cross-Origin-Embedder-Policy
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

OWASP · HTTP Security Response Headers
https://owasp.org/www-project-secure-headers/

Limitaciones y nivel de confianza

Alta confianza en que las cabeceras y etiquetas citadas aparecen en las evidencias proporcionadas. Confianza moderada en la interpretación de su impacto, ya que faltan código backend, configuración Cloudflare, pruebas funcionales y logs. Sin evidencia de explotación exitosa, filtración de datos, acceso no autorizado o compromiso de la web.

> **AVISO PROFESIONAL**
>
> Este documento es una interpretación técnica de un análisis automatizado pasivo, no una certificación de seguridad ni un pentest exhaustivo. Las medidas deben adaptarse al diseño real del sitio y verificarse antes de aplicarlas en producción.

Documento elaborado a partir de la evidencia facilitada por la propietaria. Fecha de análisis: 2 de noviembre de 2026.